Samantha Chalker

Application Security Expert

Seattle, WA, USA | +1 (425) 224-6263 | s@chalker.io
linkedin.com/in/samchalker github.com/ladyisatis

Summary

Security professional focused on creatively protecting applications, infrastructure, and data through nearly a decade of combined experience in blue team defensive security and red team offensive security. Consistently furthers knowledge and personal growth through problem-solving and tackling complex and varied issues.

Work Experience

Application Pentesting Consultant — Jan 2022 - Apr 2024

IBM X-Force Red

- Performed web and mobile application penetration testing, applied cryptography, network, and cloud security reviews
- Worked with clients to implement structurally secure applications before, during, and after implementation even on the most complex systems
- Provided training and classes for junior and senior colleagues and interns on topics relating to application security
- Performed project scoping and management skills to facilitate ease of communication between consultants and clients
- Developed internal tooling for identifying areas using localStorage, IndexedDB, Web Workers, WebSockets, and new features of HTML5 that warranted attention during testing

Senior Application Security Engineer — Sep 2020 - Nov 2021

NerdWallet

- Led and reformed the bug bounty practice
- Advised on engineering architecture assessments from an application security perspective
- Developed a solution for brute forcing that would learn from patterns logged to a database and employ reCAPTCHA to reduce fraudulent logins
- Mentored interns and junior colleagues
- Assisted in deploying a solution to check for secrets committed into repositories via the open source tool TruffleHog
- Performed reviews on various aspects of frontend security as well as supply chain issues

Senior Security Consultant (Contract) — Dec 2019 - Aug 2020

Twitter

- Performed penetration testing on web and mobile applications in internal & external features
- Responded to bug bounty reports and re-tested report issues after fixes were applied
- Provided assistance in the SDLC by working closely with other organizations and advising on security issues
- Set up an internal resource hub for engineers that provided learning resources and exercises

Skills

- Vulnerability Management
- Threat Modeling
- Application Security Architecture Assessment
- Bug Bounty Program Management
- Manual Code Review
- Applied Cryptography
- AWS Security Configuration Reviews
- Container Security Reviews
- Web, Mobile, Network Penetration Testing

Languages

- Java
- Python
- Golang
- JavaScript
  - Node.js
  - React / JSX
  - TypeScript
- PHP
- Ruby
- PowerShell
- Bash
- SQL
  - MySQL
  - PostgreSQL
  - SQLite

Conference Talks

WSSiP: A WebSocket Manipulation Proxy
(Black Hat, July 2017)

Presented WSSiP, a tool for viewing, interacting with, and manipulating WebSocket messages between a browser and web server, with an outward bridge for debugging and fuzzing all

- Performed incident response and advised executives on findings and next steps

Security Engineer, Threat Hunter — Jun 2018 - Apr 2019

Wealthfront

- Helped developers across the organization with security concerns along all points in the SDLC, including identifying security weaknesses, misconfigurations, and insecure code
- Set up fraud detection points using incoming data flagged ahead of time from external organizations
- Implemented SAST and DAST tooling throughout Wealthfront to help automate finding and remediating possible vulnerabilities
- Created a secure, end-to-end encrypted chat application that would serve as a backup internal communications platform while following FINRA regulations
- Worked closely with the DevOps team to evaluate AWS configuration and tooling that would flag potential issues as they arise

Security Consultant — Aug 2015 - May 2018

NCC Group

- Performed web application, web service, and mobile application penetration testing
- Handled communication with clients and remediation of vulnerabilities
- Trained fellow co-workers on testing applications involving binary protocols used by client-side JavaScript application, such as those using WebSockets
- Led sessions to encourage and advise consultants in pursuing ideas for research projects toward presentation at security conferences
- Developed several internal tools to aid in penetration testing and one public tool, WSSiP

WebSocket communications. This project is planned to be rewritten in Golang and using the Fyne GUI library in 2024.

Current Projects

- **TournamentStreamHelper (2023-present)**

  Software written in Python and React to help tournament organizers with automatically updating scoreboards for competitive video game tournament livestreams.